MSM ACADEMY

SECTION 8

Auditing the ISMS



8.1 ISMS auditing foundations
8.2 Managing an ISMS audit programme
8.3 Planning an ISMS audit
8.4 Collecting and verifying ISMS evidence
8.5 Findings and nonconformities
8.6 Reporting, closing and follow-up

MSM ACADEMY

SECTION 8 · LESSON 8.1

ISMS auditing foundations

What an audit is, who audits, and on what basis

8.1

LESSON 8.1

What an audit is

A systematic, independent, documented process

- Obtain objective evidence and evaluate it against audit criteria
- Criteria: requirements, policies, procedures and other references
- Results: audit findings, then an audit conclusion

LESSON 8.1

First, second and third party

Party	Examples	Who sets the rules
First party	Internal audit (ISO/IEC 27001 9.2)	The organization, guided by ISO 19011 and ISO/IEC 27007
Second party	Audits of suppliers; customer audits of the organization	The audit client, by agreement
Third party	Certification audits; regulatory audits	Certification-body rules, including ISO/IEC 17021-1 (Section 9)

LESSON 8.1

Internal audit versus certification audit

Same method, different rules

- Purpose: improve and assure the ISMS, versus certify conformity
- Independence: objective internal auditors, versus an accredited body
- Outputs: findings for management, versus a certification decision

LESSON 8.1

One integrated auditing approach

ISO 19011:2026 with ISO/IEC 27007:2020

- ISO 19011: the general framework for auditing any management system
- ISO/IEC 27007: the ISMS-specific guidance, following the same structure
- Taught as one approach, not two separate processes

LESSON 8.1

Principles of auditing

Principle	In an ISMS audit
Integrity · fair presentation	Honest work; truthful, accurate reporting
Due professional care	Diligence and judgement in what you sample and conclude
Confidentiality	Security and privacy of the information you see
Independence	Objectivity; no auditing of your own work
Evidence-based · risk-based	Verifiable evidence; effort focused where risk is greatest

Foundations: two perspectives

Implementer's view

- Plan internal audits that give management real assurance
- Keep auditors objective and independent
- Treat audit information as sensitive

Auditor's view

- Know which rules apply to this audit
- Audit against defined criteria
- Protect what you see

LESSON 8.1 · RECAP

Lesson 8.1 recap

- Audit: evidence evaluated against criteria
- First, second and third party; certification rules in Section 9
- One integrated approach: ISO 19011:2026 with ISO/IEC 27007:2020
- Seven principles, with confidentiality central in an ISMS

Check your understanding

An ISMS manager plans to audit the access control process she designed and runs herself. Which principle is most at risk?

A Independence

B Fair presentation

C Evidence-based approach

D Due professional care

Check your understanding

An ISMS manager plans to audit the access control process she designed and runs herself. Which principle is most at risk?

- **A** **Independence**
- **B** Fair presentation
- **C** Evidence-based approach
- **D** Due professional care

Answer: A

Auditors should not audit their own work. Independence, the basis of objectivity, is compromised when the auditor designed and operates the process.

MSM ACADEMY

SECTION 8 · LESSON 8.2

Managing an ISMS audit programme

8.2

Deciding what to audit, when, and with whom

LESSON 8.2

Programme objectives and scope

How much auditing, and why

- Objectives set the purpose of the programme as a whole
- Scope of the programme: sites, people, information systems, complexity
- Significance of information security risks drives depth and time

LESSON 8.2

ISMS inputs to the programme

What the ISMS tells the programme

- Information security requirements and ISO/IEC 27001 requirements
- Performance: events, incidents and effectiveness results
- Risks to the auditee and the audit client; previous audit results; changes

LESSON 8.2

Programme risks and opportunities

What can go wrong with the programme itself

- Not enough time, competence or access to the right information
- Audits that put the auditee’s information at risk
- Information security and confidentiality measures agreed in advance

LESSON 8.2

Roles and competence

Who does what, and what they need to know

- Programme manager, audit team leader, auditors, technical experts, observers, guides
- Team knowledge of information security risk management and controls
- IT and security knowledge, business understanding, remote-audit technology skills

LESSON 8.2

The internal audit programme in the MSM toolkit

Toolkit document	What it supports
L2-PRC-007 Procedure for internal audit	Programme planning, auditor selection, conduct, reporting, follow-up
L5-TMP-021 Internal audit schedule	The programme for the period: areas, dates, auditors
Finding categories in the toolkit	Nonconformity (NC), observation (OBS), opportunity for improvement (OFI)

Programme: two perspectives

Implementer's view

- Plan by risk, not by calendar alone
- Give significant risks enough time
- Match auditor competence to the topics

Auditor's view

- Ask why areas were chosen
- Check auditor independence and competence
- Look for coverage of the whole scope over time

Lesson 8.2 recap

- Objectives and the scope of the programme
- ISMS inputs: requirements, performance, risks, changes
- Programme risks include risks to the auditee’s information
- Roles and ISMS-specific competence

Check your understanding

An internal audit programme gives every ISMS area the same two hours each year, including a critical customer-data platform. What is the main weakness?

A The programme is too long

B Equal time ignores the significance of risks; critical areas need deeper audit

C Internal audits must be done by external auditors

D Two hours is the minimum set by ISO 19011

Check your understanding

An internal audit programme gives every ISMS area the same two hours each year, including a critical customer-data platform. What is the main weakness?

A. The programme is too long

B. Equal time ignores the significance of risks; critical areas need deeper audit

C. Internal audits must be done by external auditors

D. Two hours is the minimum set by ISO 19011

Answer: B

The programme should reflect the significance of information security risks. Equal time means critical areas are audited too lightly.

MSM ACADEMY

SECTION 8 · LESSON 8.3

Planning an ISMS audit

Criteria, sampling, methods and protection

8.3

LESSON 8.3

Objectives, scope and criteria

Element	In an ISMS audit
Objectives	E.g. does the ISMS identify and address security requirements? Do controls conform?
Scope	Locations, functions, processes, information systems and period covered
Criteria	ISO/IEC 27001; policy and objectives; risk criteria and processes; SoA and its controls
Further criteria	Contracts, customer and supplier security requirements, legal requirements

LESSON 8.3

Sampling

Judgement and statistics

- Judgement-based: previous results, complexity, change, significant risks, monitoring
- Statistical: when a defensible estimate of uncertainty is needed
- Sample interfaces between functions; accept only verifiable evidence

LESSON 8.3

Audit methods, including remote

The main change in ISO 19011:2026

- Remote auditing methods: from anywhere other than the auditee’s location, incl. virtual locations
- Agreed access, technical checks, contingency time; joint responsibility with the auditee
- Permission before screenshots or recordings; privacy during breaks

LESSON 8.3

Protecting information during the audit

The audit must not become the incident

- Clearance where needed; agree in advance what evidence cannot be shown
- Recognize risks the audit creates: disclosure, alteration, accidental deletion
- Classify work documents; report the effect of any unavailable evidence

LESSON 8.3

Work documents: the audit checklist

Toolkit document	Use it to
L5-TMP-022 Audit check list	Plan questions from the criteria and record evidence
Requirement / assessment point	The criterion, in the auditor’s own words
Audit findings column	Documents, records, activity witnessed, with references
Classification	Handle completed checklists as sensitive documents

Planning: two perspectives

Implementer's view

- Prepare the evidence you can and cannot show
- Agree remote arrangements early
- Brief guides on the audit plan

Auditor's view

- Define criteria including the SoA
- Sample by risk and interfaces
- Plan protection of what you will see

LESSON 8.3 · RECAP

Lesson 8.3 recap

- Criteria include the risk processes and the SoA
- Sample by judgement or statistics; never all controls by rote
- Remote methods: agreed access, tests, contingency, permissions
- Protect information; report unavailable evidence

Check your understanding

During planning, the auditee says its customer database cannot be shown because it holds personal data. What should happen first?

A Cancel the audit

B Ignore the area and say nothing in the report

C Decide whether objectives can still be met or other evidence or arrangements are needed

D Ask the auditee to copy the database to the auditor’s laptop

Check your understanding

During planning, the auditee says its customer database cannot be shown because it holds personal data. What should happen first?

A. Cancel the audit

B. Ignore the area and say nothing in the report

C. **Decide whether objectives can still be met or other evidence or arrangements are needed**

D. Ask the auditee to copy the database to the auditor’s laptop

Answer: C

The guidance is to decide whether the audit can meet its objectives without that evidence, or what alternative evidence or access arrangements are needed, and to plan for the limitation.

MSM ACADEMY

SECTION 8 · LESSON 8.4

Collecting and verifying ISMS evidence

8.4

Trails, risks, SoA and controls

LESSON 8.4

Sources of evidence

Beyond interviews and documents

- Interviews, observation, documents and records
- Logs, configuration data, information processing facilities, automated tools
- Technical verification supports evidence; S8 does not teach penetration testing

LESSON 8.4

Following audit trails

From risk to evidence and back

- Risk → treatment → SoA → control → evidence of operation → monitoring
- Controls should trace back to risk results and to policy and objectives
- Trails cross functions: IT, HR, suppliers, management

LESSON 8.4

Auditing the risk process and the SoA

Consistency checks, not a new risk assessment

- Similar risks assessed similarly; differences explained; comparable over time
- Owners with accountability and authority; acceptance within authority
- Treatment plan built from treatment outputs; controls audited against it

LESSON 8.4

Auditing Annex A controls by evidence

The organization’s specification, not the Annex A wording

- Audit the controls the SoA declares necessary, sampled by risk
- Against the organization’s own specification of each control
- Evidence of operation over time; procedures only where the organization requires them

Role play: “Just let me share my screen”



Jonas Ekberg IT Manager, Northfield Logistics

“Easiest thing is if I share my screen and open the live customer system. You can look at anything you want.”

YOU

Your move: You need evidence that access reviews happen. What do you say?

LESSON 8.4 · ROLE PLAY

One way to say it

“Thanks, that’s kind. I don’t need customer data, though. Could you show me the last two access review records instead, and the user list from one review? If a screenshot would help, I’ll ask you first.”

Why it works

- Thanks him and keeps his cooperation
- Asks only for the evidence the question needs
- Asks permission before any screenshot

Evidence: two perspectives

Implementer's view

- Prepare evidence that answers likely questions
- Offer records, not live production data
- Explain your controls as specified

Auditor's view

- Follow trails across functions
- Test consistency of risk results
- Audit controls against the organization’s specification

LESSON 8.4 · RECAP

Lesson 8.4 recap

- Evidence includes logs, configuration data and observation
- Follow trails from risk to control to evidence
- Audit the risk process for consistency, authority and traceability
- Audit controls against the organization’s specification

Check your understanding

The SoA says control 8.15 (logging) is implemented. The organization’s logging standard requires weekly review of firewall logs. What best tests the control?

A Confirm a logging policy exists

B Compare the policy with the Annex A wording

C Ask the IT manager whether logs are reviewed

D Sample review records across several months against the weekly requirement

Check your understanding

The SoA says control 8.15 (logging) is implemented. The organization’s logging standard requires weekly review of firewall logs. What best tests the control?

A. Confirm a logging policy exists

B. Compare the policy with the Annex A wording

C. Ask the IT manager whether logs are reviewed

D. Sample review records across several months against the weekly requirement

Answer: D

Audit against the organization’s own specification, with evidence of operation over time: sampled weekly review records across several months.

MSM ACADEMY

SECTION 8 · LESSON 8.5

Findings and nonconformities

8.5

From evidence to well-formed findings

LESSON 8.5

From evidence to findings

Evaluate evidence against criteria

- Findings can show conformity or nonconformity
- When the audit plan asks: good practice, opportunities for improvement, recommendations
- Review nonconformities with the auditee; record any unresolved disagreement

LESSON 8.5

Writing a nonconformity

Criteria, evidence, statement

- The criterion: what was required, in your own words, with its source
- The evidence: what you saw, where, and the sample
- The statement: why the criterion is not fulfilled; grade, if used

LESSON 8.5

Grading findings

Grading depends on the applicable scheme or defined criteria

- Grading is optional: numbers (1–5) or words (minor, major)
- Criteria must be defined and communicated by the auditing organization
- Internal audits may use the organization’s scheme; certification classification is in Section 9

LESSON 8.5 · EXERCISE

Exercise: writing ISMS findings

Northfield Logistics, internal audit evidence:

1 Access reviews are required quarterly; records exist for 2 of the last 4 quarters.
2 Monthly backup restore tests: all recorded; one failure was ticketed and re-tested successfully.
3 The SoA marks 5.20 implemented; the cloud host contract has no incident-notification clause.
4 5 of 6 staff interviewed knew how to report incidents; the sixth started this week, induction booked.

Classify each item. Then write the nonconformity for item 1.



Pause the video

Then compare with the model answer.

Model answer: writing ISMS findings

Classification	1 Nonconformity · 2 Conformity (good practice) · 3 Nonconformity · 4 Conformity; possibly an OFI on induction timing
Item 1 criterion	Access-rights review each quarter (Northfield access procedure, implementing 5.18 declared in the SoA)
Item 1 evidence and statement	Review records sampled for the last four quarters: two found. Reviews were not performed at the defined frequency.

Criterion, evidence, statement; no solution offered.

Findings: two perspectives

Implementer's view

- Acknowledge accurate evidence
- Discuss disagreements during the audit
- Own the corrective action

Auditor's view

- Write criterion, evidence, statement
- Use only the defined grading scheme
- Never prescribe the solution

LESSON 8.5 · RECAP

Lesson 8.5 recap

- Findings: conformity or nonconformity, plus good practice and OFIs if planned
- Nonconformity = criterion + evidence + statement
- Grading depends on the applicable scheme or defined criteria
- Corrective action belongs to the auditee

Check your understanding

An internal auditor writes: “Major NC: install a SIEM tool to fix weak log monitoring.” What is wrong?

A. Nothing: it is clear and actionable

B. It prescribes a solution and lacks criterion and evidence; grading must follow defined criteria

C. It should have been written as an observation

D. Internal audits cannot record nonconformities

Check your understanding

An internal auditor writes: “Major NC: install a SIEM tool to fix weak log monitoring.” What is wrong?

A. Nothing: it is clear and actionable

B. It prescribes a solution and lacks criterion and evidence; grading must follow defined criteria

C. It should have been written as an observation

D. Internal audits cannot record nonconformities

Answer: B

The finding prescribes a solution, has no criterion or evidence, and uses “major” without reference to a defined grading scheme.

MSM ACADEMY

SECTION 8 · LESSON 8.6

Reporting, closing and follow-up

8.6

From findings to results management can use

LESSON 8.6

Audit conclusions and the closing meeting

What the audit means

- Conclusions: how far criteria are fulfilled; whether objectives were met
- Closing meeting: findings, conclusions, sampling caveat
- Agree how findings will be handled and followed up

LESSON 8.6

The audit report

Report element	Toolkit support
Objectives, scope, criteria, team, dates and locations	L5-TMP-023 audit report format
Findings with evidence; conclusions	Report plus checklist references
Limits: unavailable evidence, unresolved issues	Stated without revealing sensitive content
Nonconformity records	L5-TMP-026 nonconformity report (NCR)

LESSON 8.6

Distributing and protecting reports

A report describes weaknesses

- Agreed recipients only; on time; dated and reviewed
- Classified according to content
- Encryption as one measure for electronic distribution

LESSON 8.6

Completing the audit and follow-up

Closing the loop

- The audit completes when planned activities are done or as agreed
- Follow-up verifies corrections and corrective actions, and their effectiveness
- Internal audit results are reported to relevant management (9.2.2)

Reporting: two perspectives

Implementer's view

- Receive the report as input to improvement
- Protect it like any sensitive record
- Plan corrective actions with owners and dates

Auditor's view

- Report findings, conclusions and limits
- Control distribution
- Verify effectiveness, not just completion

LESSON 8.6 · RECAP

Lesson 8.6 recap

- Conclusions and closing meeting, with the sampling caveat
- Report includes limits from unavailable evidence
- Distribution controlled; encryption for electronic copies
- Follow-up verifies effectiveness; results go to management

Check your understanding

At follow-up, the auditee shows that a new access-review procedure was approved. Nothing else has changed. What should the auditor conclude?

A The corrective action is complete and effective

B The nonconformity can be closed because a procedure exists

C Completion is partly shown, but effectiveness is not: reviews have not yet been performed

D Follow-up is not part of an audit

Check your understanding

At follow-up, the auditee shows that a new access-review procedure was approved. Nothing else has changed. What should the auditor conclude?

A. The corrective action is complete and effective

B. The nonconformity can be closed because a procedure exists

C. **Completion is partly shown, but effectiveness is not: reviews have not yet been performed**

D. Follow-up is not part of an audit

Answer: C

A new procedure shows an action was taken, but effectiveness needs evidence that reviews now happen at the required frequency.

LESSON 8.6

What Section 11 will ask of you

Skill from Section 8	How Section 11 uses it
Programme and planning reasoning	Planning the Quenvale certification audit
Remote methods and protecting information	Auditing Quenvale’s cloud and remote teams
Trails, risk process, SoA and control evidence	Following Quenvale’s evidence across functions
Well-formed, graded findings	Writing Quenvale findings under Section 9 rules
Closing, report and follow-up	Closing meeting and report for Quenvale

SECTION 8 · SUMMARY

Auditing the ISMS in one view

- One integrated approach: ISO 19011:2026 with ISO/IEC 27007:2020
- Programme and plan by risk; protect information throughout
- Follow trails; audit risk, SoA and controls by evidence
- Write findings as criterion, evidence, statement; report and follow up

SECTION 8 COMPLETE

Next: Section 9

The certification process

